



REFAZ.STUDIO

PRISMA DIDs

On-Chain Interaction Layer Security Audit Report — Consolidated D1

Audit Date	June 25, 2026
Auditor	Refaz Studio
Scope	Source Code Review + Empirical On-Chain Data Analysis + Infrastructure & Dependency Audit + Data Protection (GDPR / LGPD) Assessment
Protocol	Cardano DID/VC via CIP-20-style Metadata Transactions
Labels Audited	199674 (DID), 199675 (VC)
Repository	PrismaCardano/dids
Network	Cardano Preprod (Blockfrost API)
Components	SDK (packages/sdk) · Schemas (packages/schemas) · Indexer (apps/indexer) · Dashboard & VC-Interface (apps/*) · Deployment config (Railway)
Methodology	Complete source code review + empirical analysis of 8 on-chain transactions with COSE signature decoding + dependency audit against the pnpm lockfile + technical-regulatory analysis under GDPR and LGPD
Scoring Standard	CVSS v3.1 for all security findings; complementary data-protection severities for compliance findings

1. Executive Summary

Prisma DIDs does not use Plutus smart contracts. The protocol achieves on-chain anchoring through CIP-20-style metadata transactions submitted to the Cardano ledger under custom labels 199674 (DID events) and 199675 (VC events). This audit covered the SDK, schema definitions, and indexer components within the repository, the software-dependency and deployment-configuration surface, and the data-protection posture of the protocol under the European General Data Protection Regulation (GDPR) and, secondarily, the Brazilian Lei Geral de Proteção de Dados (LGPD).

Risk Profile

Severity	Count	Key Themes
MEDIUM-HIGH	1	PII exposure in on-chain signature payloads (CVSS 5.2)
MEDIUM	5	Unconstrained revocation reason field (CVSS 3.7); deferred authorization (CVSS 3.7); non-canonical signing (CVSS 2.1); client-side exposure of the Pinata API secret; missing HTTP security headers / CSP in the web apps (F-WEB-01)
LOW-MEDIUM	6	Timestamp gap (CVSS 1.3); fragile key extraction (CVSS 2.7); schema passthrough (CVSS 3.7); schema drift (resolved); credential presentation in URL (F-WEB-02); credentials in browser localStorage (F-WEB-03)
LOW	5	No address validation; cross-impl crypto risk; issue payload binding skip; duplicate storage; API rate-limit / size-limit gaps (F-WEB-04)
INFO	8	Design notes; resolved anomalies; architectural observations; non-reachable Drizzle SQL-injection advisory
POSITIVE	16	Secure patterns confirmed across cryptography, integrity, infrastructure, dependency hygiene, and web-app hardening (no XSS sinks, locale allowlist, no CSRF surface)
DATA PROTECTION	5	On-chain personal data, free-text PII vector, contextual identifiability, international transfer, data-subject rights

Overall Assessment

The protocol's integrity and authentication story is strong. Every on-chain event is cryptographically verified at ingest time. Event-type-aware authorization ensures only legitimate actors can issue, validate, and revoke credentials. The indexer implements production-quality infrastructure including reorg handling, confirmation tracking, and crash recovery. Private keys never leave the user's wallet.

The remaining concerns are concentrated in data minimization and privacy — specifically what semantically rich data reaches the permanent blockchain record, rather than whether that record is authentic or has been tampered with.

The infrastructure and dependency review (Domain III, Section 3) confirms a favourable posture against the Catalyst acceptance criterion: there is **no Critical vulnerability on the production surface**, and the cryptographic core (@noble/ed25519, cborg, bs58, @emurgo/cardano-serialization-lib) carries **no known advisories**. The High-severity findings on the production surface are concentrated in network and web-framework libraries, are predominantly availability (DoS) issues, and are in their majority remediable by a simple version bump. The one actionable hardening item is the exposure of the Pinata API secret in the client bundle via the NEXT_PUBLIC_ prefix.

A source-level OWASP Top 10 review of the two Next.js apps found no Critical or High issues; the main hardening item is the absence of HTTP security headers and a Content-Security-Policy in both apps (F-WEB-01).

The data-protection review (Domain IV, Section 4) is where the most material residual risk concentrates. The same finding that anchors the technical report (F-META-01) is, in regulatory terms, the embedding of semantically rich personal data in a permanent, public, immutable ledger. Read under the GDPR, this engages the principles of data minimisation (Art. 5(1)(c)), data protection by design (Art. 25), and the right to erasure (Art. 17), and aligns directly with the architectural pattern the French supervisory authority (CNIL) recommends for blockchain: keep personal data off-chain and commit only a hash or pointer on-chain. The protocol already does exactly this on the DID path; the gap is that the Verifiable Credential path does not.

2. Detailed Findings (CVSS v3.1 Scored)

The findings in this section are reproduced unchanged from the on-chain interaction-layer review. Severity scores follow CVSS v3.1.

2.1 MEDIUM-HIGH Severity

F-META-01: Verifiable Credential Claim Data Embedded in On-Chain Signatures

MEDIUM-HIGHCVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N**5.2**

ID: F-META-01 | Location: vc-anchor.ts; on-chain label 199675 | CWE: CWE-200 | Base Score: 5.2 (MEDIUM)

Description: While top-level VC metadata fields carry only pointers (vcHash as UUID, DIDs as stake addresses), the payloadSig COSE_Sign1 envelope embedded in the same metadata contains the full signed credential payload — including semantically rich claims about individuals.

Attack Vector: Network (N) · Complexity: Low (L) · Privileges: None (N)

Evidence (decoded from on-chain transaction `e856e6bd...`):

```
{
  "projectId": "Alfred Project",
  "contributionType": "mentorship",
  "hours": 10,
  "organization": "Alfred Project",
  "evidenceUrl": "https://app.zoom.us/jc/8750572108/join?...pwd=U0x4SWRwZjNOYnJCTUZwYXZSbXJ3dz09...",
  "iss": "did:cardano:stake_test1uzcsa2dkz...",
  "sub": "did:cardano:stake_test1uz0nz5vu2j...",
  "vct": "ContributionCredential",
  "_sd": ["Ty0pju67IBQFiL1mPxZUjBWjRqNhyxCheexZ-1yPIY"]
}
```

Data categories permanently recorded: Project/organization names, contribution types, evidence URLs with embedded session passwords, issuer-holder relationship graph.

Mitigating factors: Data is obfuscated (CBOR-encoded inside chunked hex arrays), not trivially readable from block explorers, but not encrypted — any motivated party can decode it.

Empirical verification: Transaction e856e6bd... confirmed on chain at block 4,458,967 with event type "issue", vcType "ContributionCredential", ipfsCid present, and payloadSig spanning 31 chunks.

Recommendation: Evaluate whether payloadSig must be stored on-chain in full; consider encrypting claim data within COSE payload; assess LGPD/GDPR compliance with legal counsel.

2.2 MEDIUM Severity

F-META-03: Revocation reason Field — Unconstrained at All Layers

MEDIUMCVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N**3.7**

ID: F-META-03 | Location: vc-anchor.ts:234; vc-event.ts; label 199675 | CWE: CWE-20 | Base Score: 3.7 (LOW)

Description: The reason field in VC revocation events is free-text, unsanitized, length-unlimited, and written permanently to a public blockchain. It passes through every layer without validation.

Attack Vector: Network (N) · Complexity: Low (L) · Privileges: None (N)

Layer trace:

Layer	Component	Validation
1. Caller	anchorVCRevocation()	None — accepts any string
2. SDK Builder	vc-anchor.ts:234	Passthrough — no trim/regex/enun
3. Schema	vc-event.ts Zod	z.string().optional() only
4. Signature	wallet.signData()	Signs content without inspection
5. Indexer	makeRow()	Stores as-is, no filtering
6. Ledger	Cardano blockchain	PERMANENT, PUBLIC IMMUTABLE

Current usage (clean): "reason": "issued_in_error" — confirmed across all 3 duplicate revocation transactions on chain.

Potential abuse: "Revoked: João Silva, CPF 123.456.789-00, fired for embezzlement" — irreversible GDPR/LGPD Article 17 violation once written to chain.

Recommendation: Define allowlist enum (issued_in_error | expired | compromised | withdrawn_by_holder); add max length 64 chars; implement PII keyword filter.

F-SIG-01: Non-Canonical JSON Signing

MEDIUMCVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:A/E:RL2.1

ID: F-SIG-01 | Location: vc-anchor.ts:116; signature.ts:21 | CWE: CWE-345 | Base Score: 2.1 (LOW)

Description: The signing path uses JSON.stringify() without canonical key ordering, despite the codebase containing a stableSort() function used for deterministic serialization in hash computation.

Attack Vector: Network (N) · Complexity: High (H) · Privileges: None (N)

Mitigating factor significant: The indexer implements order-independent payload comparison that renders this low-risk for VC events:

```
// vc-processor.ts — jsonPayloadMatch()
export function jsonPayloadMatch(
  signedPayload: Uint8Array,
  expected: Record<unknown>,
): boolean {
  const signed = JSON.parse(new TextDecoder().decode(signedPayload));
  return Object.keys(expected).every(
    (key) => signed[key] === expected[key]
  ); // Key-order independent ✓
}
```

Status: Functional today due to same-engine signing/verification and indexer's order-independent comparison. Fragile across future cross-implementation diversity.

Recommendation: Replace JSON.stringify(fields) with JSON.stringify(stableSort(fields)). Cost: ~30 minutes.

F-IDX-03: Revocation Authorization Deferred to Query Time

MEDIUMCVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L3.7

ID: F-IDX-03 | Location: vc-processor.ts (revoke case); vc.ts (status reducer) | Base Score: 3.7 (LOW)

Description: VC revocations are verified for cryptographic validity and stored at ingest time, but authorization (signer == legitimate issuer) is not checked until query time when the status reducer runs. Unauthorized revocations are accepted into the database and permanently stored, even though they don't affect credential status.

Attack Vector: Network (N) · Complexity: Low (L) · Privileges: None (N)

Security analysis: The status reducer correctly ignores unauthorized revocations — credential status cannot be flipped by an attacker. However: storage bloat from floodable validly-signed revocations; reason field abuse surface compounds F-META-03; every revoke triggers expensive COSE verification even if ultimately ignored (DoS vector).

Recommendation: Consider adding ingest-time signer==issuer check; add rate limiting per vcHash or signer address if keeping current design.

2.3 LOW-MEDIUM Severity

F-SIG-03: DID Event Timestamp Outside Signature Scope

LOW-MEDIUM CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:N/I:L/A:E:P1.3

ID: F-SIG-03 | Location: signature.ts:buildDIDEvent | Base Score: 1.3 (LOW)

DID events add ts after signing (unsigned). VC events correctly include ts inside signature. Empirically confirmed via decoded on-chain signatures: DID create transaction returns {action:"create", ts:"2026-05-04T21:26:31.795Z", id_chunks:2, has_payloadSig:true}.

Attack Vector: Network (N) · Complexity: High (H) · Privileges: High (H)

Recommendation: Move ts before signing in signDIDPayload(), consistent with VC pattern.

F-KEY-03: COSE_Key Extraction Uses Fragile Byte-Scanning

LOW-MEDIUM CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:U2.7

ID: F-KEY-03 | Location: keys.ts:extractRawPublicKey | CWE: CWE-123 | Base Score: 2.7 (LOW)

Manual byte-pattern scanning for 0x58 0x20 marker with silent fallback to slice(-32) returning wrong data on malformed input. Inconsistent with rest of codebase which uses cborg.decode(). Current risk low — fast path handles normal cases. Recommendation: Replace with proper CBOR parsing using already-imported cborg library.

F-SIG-08: VC Schema Allows Silent Extra-Field Injection

LOW-MEDIUM CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N3.7

ID: F-SIG-08 | Location: vc-event.ts:VCEventPayloadSchema | Base Score: 3.7 (LOW)

Zod schema uses .passthrough(), allowing unknown fields to pass validation silently. No structural guardrail against field injection. Recommendation: Remove passthrough during development; keep in production only if backward compatibility requires documented justification.

F-SIG-07: Schema/Code Mismatch for ipfsCid Field

LOW-MEDIUM — N/A — INFO

Status: Resolved

VC event schema declares ipfsCid as optional for issue events, but SDK builder has no parameter/logic to populate it. Origin confirmed as external enrichment. Verifiers should not rely on ipfsCid being present in VC issue events.

2.4 LOW Severity

F-SIG-05: Credential Payload Binding Non-Canonical in SDK

LOW

ID: F-SIG-05 | Location: vc-verify.ts:step 3

SDK-side credential verification uses `JSON.stringify(payload)` without canonicalization. Mitigated by indexer's `jsonPayloadMatch()` for on-chain events. Low risk — same-codebase signing and verification.

F-KEY-05: No Address Validation Before Wallet Signing

LOW

ID: F-KEY-05 | Location: signature.ts:13; vc-anchor.ts:116

`signingAddress` passed to `wallet.signData()` not validated as properly-formatted Cardano base address. Relies on caller/wallet for correctness. Correct architectural separation, but cheap defense-in-depth available via `Address.validate_bech32()`.

F-IDX-05: Issue Events Skip Payload Binding

LOW

ID: F-IDX-05 | Location: vc-processor.ts (issue case)

VC issue events reuse credential's own `COSE_Sign1` signature (signed claim data), not anchor metadata fields. Payload binding intentionally skipped — "COSE validity + signer matching is sufficient." Acceptable design with documented rationale.

F-META-02: Duplicate On-Chain Events

LOW — Status: Mitigated by indexer

Empirically confirmed: 2 duplicate DID creates, 3 duplicate VC revocations on preprod. All 3 revocations share identical `vcHash` `urn:uuid:53ca5da9-488e-4738-9e49-84c83be1e4de` with reason `"issued_in_error"`.

Mitigation: DID dupes caught by `chain-validator.ts` (second create rejected as `duplicate_create`). VC dupes all stored; status reducer deterministically selects earliest authorized event (tx 114d72... at 16:56:43Z). No action required — handling is correct and deterministic.

2.5 Informational Findings

ID	Area	Title
F-META-05	Metadata	On-chain schema drift: 7+ fields vs original 5-field model; ts and payloadSig added post-design
F-META-06	Privacy	Stake-address DIDs are permanently linkable — pseudonymous, not anonymous. Design decision worth documenting.
F-KEY-04	Architecture	CIP-30 bridge clean: injected dependency, no wallet.enable(), proper library/app separation

2.6 Positive Findings (Secure Patterns Confirmed)

ID	Area	Finding
F-KEY-01	Keys	Private keys never touch SDK. All signing delegated to CIP-30 wallet via wallet.signData(). SDK receives only public materials + signature.
F-KEY-02	Crypto	@noble/ed25519 async-only. Independently audited, constant-time, zero dependencies, WebCrypto SHA-512 path.
F-SIG-04	Crypto	COSE_Sign1 verification RFC 8152 compliant. Proper 4-element array decode, correct Sig_structure, pubkey from COSE_Key key -2.
F-IDX-01	Indexer	Order-independent payload comparison. jsonPayloadMatch() parses signed bytes to object, compares key-by-key, renders insertion order irrelevant.
F-IDX-02	Indexer	Comprehensive chain validation. Fork detection, version monotonicity, duplicate prevention, prev-linkage enforcement.
F-IDX-04	Indexer	Production-quality poller. Reorg handling (DELETE + checkpoint reset), confirmation pass, adaptive backoff (30s→180s cap), crash recovery, heartbeat optimization.
F-IDX-06	Indexer	Deterministic status reduction. Sort by blockHeight→txIndex→txHash; canonical issuer from earliest issue; first authorized revoke wins;

ID	Area	Finding
		unauthorized revocations have zero effect.
F-KEY-06	Keys	Multibase conversion spec-compliant. Multicodec 0xED 0x01, Base58BTC, z-prefix, regex validation. Per W3C DID spec.
F-META-07	Metadata	DID path uses pure pointer model. Only IPFS CID on-chain — no document content. Confirmed empirically via Blockfrost.
F-META-08	Metadata	64-byte chunking working in production. Long strings correctly split per CBOR/Cardano limits. Verified against real chain data.

3. Infrastructure & Development Security (Domain III)

3.1 Objective and Perimeter

Domain III assesses the security of the development environment, software dependencies, and deployment infrastructure of Prisma DIDs. Unlike a traditional blockchain-application audit, there are no smart contracts to verify the project does not use Plutus. Risk therefore concentrates on three fronts: the dependency graph (third-party libraries and their known vulnerabilities), secret handling and deployment configuration, and the web-application security posture (dashboard and credential interface) against the OWASP Top 10. This section documents the two fronts that are fully realizable from the source code the dependency audit and the in-repository secret/configuration hygiene. The remaining fronts are listed as open items in Section 3.5.

3.2 Methodology

The evaluation was conducted over the project monorepo (pnpm + Turborepo) at the revision corresponding to the supplied pnpm-lock.yaml. The steps were: (1) running pnpm audit against the lockfile, which cross-references the exact resolved dependency versions with public security-advisory databases; (2) re-running with the --prod cut to isolate the deployed artefact's dependencies from development-only tooling (test runners, bundlers, linters); (3) mapping each vulnerable package to its host module across apps/dashboard, apps/vc-interface, apps/indexer, packages/sdk, packages/crypto, and packages/schemas; (4) source-level verification of the highest apparent-severity finding (the Drizzle ORM SQL-injection advisory); (5) inspection of .gitignore, .env.example, and railway.toml for secret and configuration hygiene; and (6) a source-level OWASP Top 10 review of the dashboard and vc-interface apps (security headers, XSS, CSRF, input validation, SSRF).

3.3 Findings

F-DEP-01: Production Dependency Vulnerabilities — Network/Framework Surface

MEDIUM (aggregate) — Patchable by version bump

The audit identified the following picture of known vulnerabilities:

Cut	Total	Critical	High	Moderate	Low
Production + development	86	1	40	37	8
Production only	60	0	27	27	6

The single **Critical** advisory is located in vitest (the test runner), a development-only dependency absent from the production bundle. There is no Critical vulnerability on the production surface, so the Catalyst acceptance criterion (no unresolved Critical findings) is not threatened by the dependency graph.

The production High-severity advisories concentrate in network and web-framework libraries:

Package	Module	Nature of vulnerability	Dimension affected
axios	sdk	NO_PROXY bypass; null-byte injection	Network
ws	dashboard	Memory exhaustion (DoS); uninitialized-memory leak	Availability Confidentiality
next	dashboard, vc-interface	DoS via Server Components; HTTP request smuggling in rewrites	Availability / Integrity
fastify	indexer	Body schema-validation bypass	Integrity
drizzle-orm	indexer	SQL injection via mis-escaped identifier	See §3.4 (not reachable)
form-data	transitive	CRLF injection in multipart	Network
fast-uri	transitive (via fastify)	Path traversal via encoded dot	Integrity
next-intl	dashboard, vc-interface	Open redirect	Social engineering

Two qualifications apply. First, the majority of High findings concern availability (denial of service) rather than direct confidentiality/integrity compromise, a generally less severe exploitation profile. Second, almost all are remediable by a version bump: the audited lockfile predates most of these advisories, so the expected remediation is a dependency update and lockfile regeneration, at low effort. Recommendation: run `pnpm update`, regenerate the lockfile, and re-audit before production.

F-DEP-02: Drizzle ORM SQL Injection — Present in Dependency, Not Reachable in Code

INFO — Downgraded after source-level verification

The drizzle-orm advisory materialises only when SQL identifiers (table or column names) are built from user-controlled input and not properly escaped. Direct inspection of the indexer's database-access code found that this condition is not present: every user-derived filter uses the library's parameterized operators — `eq()`, `and()`, `inArray()` (verified in `apps/indexer/src/api/routes/vc.ts`, among others); raw-SQL usages (`sql\...\``) contain only “static schema column references” and “bound values” (e.g. `${confirmBelow}`, `${reorgHeight}``), which the library binds as parameters; and no table/column identifier originates from external input. Conclusion: the vulnerability exists in the dependency but is not reachable as the code uses it. This is patch hygiene (keep the library current), not an exploitable flaw.

F-CFG-01: Sensitive Secrets Exposed in the Client Bundle via NEXT_PUBLIC_

MEDIUM

In Next.js, any environment variable prefixed `NEXT_PUBLIC_` is **embedded into the JavaScript shipped to the browser** and is therefore readable by any user. The project's configuration model exposes, through this prefix, credentials that should remain server-side:

- `NEXT_PUBLIC_PINATA_API_KEY` and `NEXT_PUBLIC_PINATA_API_SECRET` (and the `NEXT_PUBLIC_PINATA_JWT` referenced in deployment docs);
- `NEXT_PUBLIC_BLOCKFROST_PREPROD_KEY`.

The most serious case is the **Pinata API secret**: exposed client-side, anyone can extract it and operate the organization's Pinata account (pin/manage content, exhaust quota, generate cost). The Blockfrost key in the client is a more common ecosystem practice (a rate-limited read key), but still a deviation from best practice worth recording. Recommendation: move any operation that requires the Pinata secret to a server route, keeping only genuinely public read keys in the client. Severity is conditional on confirming, in the Railway panel, whether the Pinata secret is in fact configured as `NEXT_PUBLIC_` in production (see Section 3.5).

The following findings result from the source-level OWASP Top 10 review of the two Next.js applications (`apps/dashboard`, `apps/vc-interface`). No Critical or High issues were found.

F-WEB-01: Missing HTTP Security Headers / No Content Security Policy

MEDIUM

ID: F-WEB-01 | Location: `apps/dashboard/next.config.js`; `apps/vc-interface/next.config.js` | OWASP: A05 (Security Misconfiguration)

Description: Neither Next.js app defines a `headers()` block (nor middleware) to emit HTTP security headers. There is no Content-Security-Policy, Strict-Transport-Security (HSTS), X-Frame-Options / `frame-ancestors`, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy. Consequences: no defense-in-depth against XSS (a single injection has full script capability), clickjacking is possible (no `frame-ancestors`), MIME-sniffing is not blocked, and full referrer leakage compounds F-WEB-02.

Recommendation: Add a `headers()` function (or middleware) to both apps setting a strict Content-Security-Policy (e.g. default-src 'self', no inline scripts), Strict-Transport-Security, X-Frame-Options: DENY / `frame-ancestors 'none'`, X-Content-Type-Options: nosniff, Referrer-Policy: no-referrer, and a restrictive Permissions-Policy.

F-WEB-02: Credential Presentation Transported in URL Query String

LOW-MEDIUM

ID: F-WEB-02 | Location: apps/vc-interface/app/credentials/page.tsx (handleShareSubmit, handleVerify) | OWASP: A01 / A04

Description: Selective-disclosure presentations are encoded into the URL query string (`/verify?p=<presentation>`), both for the generated share link and for in-app navigation. Query strings are persisted in browser history, server and proxy access logs, and leak via the `Referer` header to third-party resources. The disclosed claims are personal data, the link carries no expiry, and anyone with the URL can replay the presentation. Absent a `Referrer-Policy` (F-WEB-01), the leakage surface is maximal.

Recommendation: Transport the presentation in the URL fragment (`/verify#p=...`), which browsers do not send to servers, logs, or the `Referer` header; or exchange it via `POST` / a short-lived one-time token. Set `Referrer-Policy: no-referrer`.

F-WEB-03: Verifiable Credentials Stored Unencrypted in Browser `localStorage`

LOW-MEDIUM

ID: F-WEB-03 | Location: apps/vc-interface/services/credentialStore.ts; credentials/issue/manage pages | OWASP: A02 / A04

Description: Issued credentials (which contain personal claim data) are persisted in the browser's `localStorage` in clear text. `localStorage` is readable by any JavaScript running on the origin, so, combined with the absence of a `Content-Security-Policy` (F-WEB-01), a single XSS could exfiltrate the holder's full credential store. Data also persists indefinitely on shared or public devices.

Recommendation: Encrypt credential data at rest (for example with a key derived from the wallet) or minimise what is stored and for how long; at minimum deploy the CSP from F-WEB-01 to reduce the XSS exfiltration path, and give the holder an explicit "clear local data" control.

F-WEB-04: Public API Routes Lack Rate Limiting and Request-Size Limits

LOW

ID: F-WEB-04 | Location: apps/vc-interface/app/api/verify/route.ts; apps/dashboard/app/api/did/[did]/route.ts | OWASP: A05 / A04

Description: The verification endpoint runs an expensive COSE_Sign1 verification on unauthenticated request bodies with no rate limiting and no explicit body-size cap, a CPU-exhaustion (DoS) vector that compounds F-IDX-03. The DID proxy does not allowlist the `network` parameter, and both routes echo internal `error.message` text to the client (minor information disclosure). Note (confirms F-CFG-01): the write-capable Pinata credential is used directly from client components (`NEXT_PUBLIC_PINATA_JWT` in `CreateDID.tsx`, `RevokeDID.tsx`, `UpdateDID.tsx`), empirically confirming that a Pinata write secret ships in the browser bundle.

Recommendation: Add per-IP rate limiting and a request-size limit; return generic error messages to clients (log details server-side); allowlist `network` against the supported set. The Pinata-secret fix is tracked under F-CFG-01.

3.4 Positive Findings (Domain III)

ID	Area	Finding
F-DEP-03	Crypto deps	Cryptographic core clean: <code>@noble/ed25519</code> (<code>^3.0.0</code>), <code>cborg</code> (<code>^4.5.8</code>), <code>bs58</code> (<code>^6.0.0</code>), <code>@emurgo/cardano-serialization-lib</code> (<code>^15.0.3</code>) carry no known advisories . Directly answers the contracted "CVEs in cryptographic packages" question: none.
F-DEP-04	Production surface	No Critical vulnerability on the production surface; the only Critical is dev-only (vitest).
F-CFG-02	Secret hygiene	<code>.gitignore</code> correctly excludes <code>.env</code> , <code>.env.local</code> , <code>.env*.local</code> ; no real <code>.env</code> file committed ; <code>.env.example</code> holds placeholders only; <code>railway.toml</code> limited to <code>build/start/healthcheck</code> with no embedded secrets.
F-WEB-P1	Web	No raw-HTML injection sinks: no <code>dangerouslySetInnerHTML</code> , <code>innerHTML</code> , <code>eval</code> , or <code>new Function</code> in either app; React auto-escaping is in effect, so the reflected/stored XSS surface is minimal.
F-WEB-P2	Web	<code>i18n</code> locale is read from a cookie but validated against an allowlist before the dynamic <code>messages/\${locale}.json</code> import, preventing path-traversal / local-file inclusion via the locale value.

ID	Area	Finding
F-WEB-P3	Web	No cookie-authenticated, state-changing endpoints: all mutations require CIP-30 wallet signatures, so classic CSRF is not applicable. Server routes resolve the indexer endpoint from config and encodeURIComponent the DID, so SSRF is not reachable.

3.5 Open Items in Domain III

Front	Status	Blocker
Dependency audit	Complete	—
In-repo secret hygiene	Complete	—
Live Railway configuration (secrets, env vars, deploy permissions)	Pending	Requires read-only access to the Railway panel (contractual pre-requisite); needed to finalise F-CFG-01 severity
OWASP Top 10 review of the Next.js dashboard (XSS, CSRF, HTTP headers, input validation)	Complete	Done in this review — see F-WEB-01 to F-WEB-04 and F-WEB-P1 to F-WEB-P3

4. Data Protection & Privacy — GDPR & LGPD (Domain IV)

4.1 Objective, Perimeter and Why GDPR Leads

Domain IV evaluates the protocol's data-protection posture, with emphasis on the risks arising from blockchain immutability as a storage medium for personal data. The analysis is framed primarily under the European General Data Protection Regulation (Regulation (EU) 2016/679, "GDPR"), because Prisma DIDs is a Catalyst deliverable addressed to a global audience and the GDPR is the most demanding and most widely recognised reference for blockchain-and-personal-data questions. The Brazilian LGPD (Lei nº 13.709/2018) is treated as a secondary, parallel mapping: it was modelled on the GDPR with roughly 80% conceptual overlap, so each finding carries an LGPD cross-reference, but the operative legal analysis is GDPR-led.

The perimeter comprises: the decentralized identifiers (DIDs) written to Cardano under label 199674; the Verifiable Credential (VC) events written under label 199675, including the COSE payloads embedded in those transactions; the storage of DID Documents and credential content on IPFS via Pinata; and the issuance/verification interfaces with respect to consent flow and data minimisation. Out of scope: user contracts and any published privacy policy not provided for review, and internal organizational processing unrelated to the on-chain protocol.

The data-protection severities below are complementary, not substitutive, to the CVSS scores of the technical report. They express regulatory-compliance risk, which can persist even when the underlying technical security risk is mitigated.

4.2 Role Mapping (GDPR / LGPD)

Actor	GDPR role	LGPD equivalent	Basis
Prisma Collective	Controller (Art. 4(7))	Controlador	Determines purposes and means; operates the protocol and interfaces
Credential-issuing organizations (e.g. ALJ programme)	Controller / joint controller (Art. 26)	Controlador / co-controlador	Decide what to credential, for whom, with which data
DID holders	Data subjects (Art. 4(1))	Titulares (Art. 5, V)	Natural persons identifiable via the DID and credentials
Pinata	Processor (Art. 4(8), Art. 28)	Operador (Art. 5, VII)	Stores DID Documents and credential content on IPFS per protocol instructions
Blockfrost	Processor	Operador	Read access to Cardano; no independent processing
Cardano network nodes	Not identifiable controllers/processors	—	Decentralized participants with no legal relationship to the controller

No DPA on record (Art. 28 GDPR / Art. 39 LGPD). The repository review identified no Data Processing Agreement with Pinata or Blockfrost. Under GDPR Art. 28(3), processing by a processor must be governed by a contract binding the processor to act only on documented instructions; under LGPD Arts. 39 and 46 the equivalent obligation applies. The absence of such a contract does not invalidate the processing, but exposes the controller to liability for processor failures (GDPR Art. 82; LGPD Art. 42 §1°).

4.3 Findings

DP-01 — Semantic Personal Data in On-Chain COSE Payloads

- **Technical correlate:** F-META-01 (CVSS 5.2, MEDIUM-HIGH)
- **Data-protection severity:** High
- **GDPR:** Art. 4(1) (personal data), Art. 4(5) + Recital 26 (pseudonymisation), Art. 5(1)(c) (data minimisation), Art. 17 (right to erasure), Art. 25 (data protection by design and by default)
- **LGPD (secondary):** Arts. 5-I, 6-III, 12, 18-VI

Description. Empirical evidence from the on-chain review showed that the COSE_Sign1 payload embedded in VC issuance events (label 199675) contains semantically rich data about the data subject. Transaction e856e6bd... on Cardano preprod revealed, in a form decodable by any party with blockchain access, the JSON shown in F-META-01, including projectId, contributionType, hours, organization, an evidenceUrl carrying an embedded session password, and the iss/sub issuer–holder relationship graph.

GDPR analysis. Under Art. 4(1), personal data is any information relating to an identified or identifiable natural person. Individually, the fields may look generic; together, they form a permanent link between two pseudonymous identifiers and concrete behavioural attributes. Recital 26 is decisive: pseudonymised data that can be attributed to a natural person by the use of additional information remains personal data, and the identifiability test considers means reasonably likely to be used by the controller or another person. The COSE content is not anonymised, it is CBOR-encoded (a binary format decodable without a key) and not encrypted;

any motivated party can decode it with public tooling. It is therefore pseudonymised personal data, not anonymous data.

The regulatory gravity is amplified by two factors. First, immutability. Art. 17 grants the right to erasure for data processed on the relevant bases; data written to Cardano is permanent by design, with no technical removal mechanism. The controller can erase the linked data it holds off-chain (database, IPFS via Pinata), but the COSE payload persists on-chain indefinitely. Second, contradiction with the selective-disclosure design. Prisma DIDs implements SD-JWT so that a holder reveals only the necessary fields per presentation; F-META-01 shows the full COSE_Sign1 payload is nonetheless written on-chain at issuance, so the privacy promise of selective disclosure is honoured at the presentation layer but defeated at the anchoring layer.

This finding maps directly onto the architectural pattern the French supervisory authority (CNIL, *Blockchain and the GDPR*, 2018) recommends: keep personal data off-chain and commit only a hash/commitment on-chain; where the controller retains the ability to re-identify from the hash, the on-chain value is pseudonymous personal data. The CNIL further accepts that deleting the off-chain mapping, while not "erasure" in the strict sense, can be treated as an effort effectively equivalent to complying with the right to erasure — but that reasoning only works if what is on-chain is a commitment, not the content itself.

Recommendation. The on-chain payload should carry only the credential's cryptographic anchor (the committed hash), not the semantic content. The full credential should remain in IPFS, accessible only via an access key controlled by the holder. This aligns the architecture with data minimisation (Art. 5(1)(c)), data protection by design (Art. 25), and the model the project already applies on the DID path (CID-only on-chain; content in IPFS positive finding F-META-07).

Severity rationale. Rated High for structural reasons, not for the sensitivity of the current data (ordinary participation attributes). What is written on-chain is permanent and public by design, and the issuance path is general-purpose: the same mechanism could later anchor far more sensitive data (health, financial, special-category) with the same irreversibility. The rating reflects the design risk, best fixed before production.

DP-02 - Revocation reason Field as a Permanent PII Vector

- **Technical correlate:** F-META-03 (CVSS 3.7, MEDIUM)
- **Data-protection severity:** High (elevated relative to the technical CVSS by permanence and irreversibility)
- **GDPR:** Art. 5(1)(c) (minimisation), Art. 9 (special-category data risk), Art. 17 (erasure), Art. 25
- **LGPD (secondary):** Arts. 5-I, 6-I/III, 18-VI

Description. The reason field in revocation events is accepted as a free string, no allowlist, no length limit, no sanitisation at any layer, from SDK to ledger. On-chain usage today is the clean value `issued_in_error`, but the code does not prevent an issuer from writing, e.g., *"Revoked: João Silva, CPF 123.456.789-00, dismissed for cause, misappropriation of funds."* Such text would be written to Cardano **permanently, publicly, and immutably**.

GDPR analysis. The hypothetical above is not improbable in organizational contexts under pressure. It would constitute the irreversible publication of personal data, and potentially special-category data under Art. 9 (information about alleged offences/employment dismissal), in a permanent public record, the opposite of data minimisation (Art. 5(1)(c)). The data subject's right to erasure (Art. 17) would be structurally unattainable. Combined with DP-01, these points to an architectural pattern that underestimates what permanently reaches the public ledger.

Recommendation: Implement a restricted enum (`issued_in_error` | `expired` | `compromised` | `withdrawn_by_holder`) with a 64-character maximum. The technical fix is trivial (~30 minutes; item P1 in the remediation matrix) and removes the risk before any production credential is revoked with free text.

DP-03 — DID Pseudonymity vs. Contextual Identifiability

- **Technical correlate:** F-META-06 (Informational)
- **Data-protection severity:** Medium
- **GDPR:** Art. 4(1), Art. 4(5) + Recital 26
- **LGPD (secondary):** Arts. 5-I, 5-XI, 12

Description. Prisma DIDs are derived from the user's Cardano wallet **stake address**, yielding identifiers of the form `did:cardano:stake1....`. F-META-06 classifies these as "permanently linkable, pseudonymous, not anonymous."

GDPR analysis. Art. 4(5) defines pseudonymisation as processing such that data can no longer be attributed to a subject without additional information kept separately. A `did:cardano:stake1...` fits squarely: it is pseudonymised, not anonymous. Consequences: the DID is **personal data for the controller** (and for any party with access to the database mapping stake addresses to real identities), even if opaque to third parties; all processing of the DID is processing of personal data subject to the GDPR; and the issuer↔holder relationship graph (iss/sub fields) is permanently public on-chain, enabling network analysis even without nominal identification. Choosing the stake address as the DID base is technically justified (persistence under key rotation) and is not, in itself, a design flaw; the data-protection risk emerges from the combination of this contextual identifiability with the volume of semantic data written on-chain (DP-01).

Recommendation. Formally document the DID as pseudonymised personal data subject to GDPR/LGPD, and surface this in the privacy notice presented at DID creation and at credential issuance.

DP-04 - IPFS via Pinata: International Transfer Without an Art. 46 Safeguard / Art. 28 DPA

- **Technical correlate:** none in the technical report (new front); related to F-CFG-01 (Pinata secret exposure)
- **Data-protection severity:** Medium
- **GDPR:** Art. 28 (processor contract), Arts. 44–49 (international transfers), Art. 46(2)(c) (Standard Contractual Clauses)
- **LGPD (secondary):** Arts. 33–36; CD/ANPD Resolution n° 19/2024

Description. Prisma DIDs stores DID Documents and full credential content on IPFS via Pinata, a US-based company with globally distributed infrastructure. The United States has no general adequacy decision applicable to this controller, and any transfer of personal data to a processor in a third country without adequacy requires a transfer mechanism under GDPR Arts. 44–49.

GDPR analysis. Content stored on IPFS via Pinata may include personal data of the holder (DID Documents with keys bound to the stake address; credential content). Even acting as an instructed processor (Art. 28), the controller must ensure: (1) a valid transfer mechanism — preferably the **Standard Contractual Clauses** in Commission Implementing Decision (EU) 2021/914 of 4 June 2021, which provide appropriate safeguards within the meaning of Art. 46(2)(c), read together with EDPB Recommendations 01/2020 on supplementary measures and a transfer impact assessment; (2) an Art. 28 processor contract binding Pinata to documented instructions and security obligations; and (3) a contractual guarantee that Pinata will not process the data for its own purposes. None of these instruments was found in the repository; the `.env.example` shows Pinata API credentials wired directly into the SDK, with no documented contractual layer. The LGPD analysis is parallel: transfer to a country without an ANPD adequacy decision requires the ANPD Standard Contractual Clauses (Res. 19/2024, Annex II).

Note on Cardano nodes. Transaction propagation across globally distributed Cardano nodes does not, by itself, constitute an international transfer in the GDPR/LGPD sense, because the nodes are not identifiable processors. However, if the on-chain metadata contains personal data (per DP-01), the question resurfaces with force, which is a further reason to keep content off-chain.

Recommendation. Execute an Art. 28 DPA with Pinata incorporating the EU SCCs (Decision 2021/914) and, for the Brazilian leg, the ANPD SCCs (Res. 19/2024, Annex II), before production launch. Assess whether DID Documents contain personal data and, if so, apply the same instrument to the IPFS storage.

DP-05 — No Documented Mechanism for Data-Subject Rights; DPIA Gap

- **Technical correlate:** none (new front)
- **Data-protection severity:** Medium
- **GDPR:** Arts. 12–22 (data-subject rights), Art. 17 (erasure), Art. 35 (Data Protection Impact Assessment)
- **LGPD (secondary):** Arts. 9, 18

Description. GDPR Arts. 12–22 grant rights of access, rectification, erasure, restriction, portability and objection. The repository shows no implemented channel or mechanism to exercise these rights, neither in the dashboard/vc-interface nor in any privacy-policy documentation. For a decentralized-identity system whose differentiator is precisely holder control over data, this absence is in tension with the product proposition.

GDPR analysis. The technical challenge is real: the right to erasure (Art. 17) collides with blockchain immutability for data already written on-chain. But a viable erasure protocol can be documented and communicated:

Data	Available erasure mechanism
DID Document (IPFS via Pinata)	Unpin and delete content — technically possible
Credential content (IPFS)	Idem
On-chain metadata (hashes, CIDs, COSE payload)	Not erasable — immutable by design
Indexer records (database)	Erasable

The controller should inform data subjects, clearly and in advance, which data cannot be erased after on-chain recording and why, consistent with the CNIL's position that deleting off-chain context is treated as an effort effectively equivalent to erasure when only commitments remain on-chain. Separately, because the protocol involves **systematic, large-scale processing of pseudonymised personal data on an immutable medium**, a **Data Protection Impact Assessment (Art. 35)** is advisable and is specifically recommended by the CNIL for blockchain projects processing personal data.

Recommendation. Implement a data-subject request channel and publish a documented response procedure; conduct a DPIA before production; and explicitly inform holders, in the issuance flow, which data is irremovable after on-chain confirmation.

4.4 The Structural Tension: Selective Disclosure vs. On-Chain Anchoring

Prisma DIDs adopts two technically recognised privacy mechanisms: SD-JWT for granular control of what the holder reveals at presentation, and the pointer model on the DID path (only the IPFS CID goes on-chain, not the document). Both are correct architectural choices and deserve recognition. The problem identified in this domain is that the Verifiable Credential path does not follow the same pointer model: while the DID writes only CID + hash on-chain (positive finding F-META-07), the VC issuance event writes the full COSE_Sign1 payload, including the credential's semantic fields. This creates a privacy asymmetry between two objects of the same system:

Object	What goes on-chain	Personal content on-chain?
DID	IPFS CID + hash	No (pointer only)
VC	Pointers + full COSE_Sign1 payload	Yes — semantic fields embedded

The required correction (DP-01, R1) is to bring the VC onto the same model as the DID: only a cryptographic anchor on-chain, content in IPFS. SD-JWT continues to serve selective disclosure at the presentation layer, but on-chain anchoring becomes proof of existence and integrity only — not a content repository. This is exactly the CNIL-recommended pattern and the most defensible posture under both GDPR Art. 25 and LGPD Art. 6-III.

4.5 Synthesis of Data-Protection Findings

ID	Title	DP severity	Technical correlate	Primary GDPR articles
DP-01	Personal data in on-chain COSE payloads	High	F-META-01 (CVSS 5.2)	Art. 4(1)/(5), 5(1)(c), 17, 25
DP-02	reason field as permanent PII vector	High	F-META-03 (CVSS 3.7)	Art. 5(1)(c), 9, 17
DP-03	DID pseudonymity — contextual identifiability	Medium	F-META-06 (INFO)	Art. 4(1)/(5), Recital 26
DP-04	IPFS via Pinata — transfer without Art. 46 safeguard/DPA	Medium	(new) / F-CFG-01	Art. 28, 44–49, 46(2)(c)
DP-05	No data-subject-rights mechanism; DPIA gap	Medium	(new)	Art. 12–22, 17, 35

4.6 Prioritized Data-Protection Remediation

Prio	Action	Effort	Finding resolved
R1	Remove the full COSE_Sign1 payload from on-chain metadata; write only the credential's committed hash	2–4 h design + implementation	DP-01 (High)
R2	Restricted enum + 64-char limit for the revocation reason field	30 min	DP-02 (High)
R3	Execute Art. 28 DPA with Pinata incorporating	Legal — 1–2 weeks	DP-04 (Medium)

Prio	Action	Effort	Finding resolved
	EU SCCs (Decision 2021/914) and ANPD SCCs (Res. 19/2024, Annex II)		
R4	Publish an Art. 12–22 data-subject-rights procedure + on-chain immutability notice in the issuance flow; run an Art. 35 DPIA	1 day + DPIA	DP-05 (Medium)
R5	Document the DID as pseudonymised personal data in the privacy notice	2–4 h	DP-03 (Medium)

4.7 Legal Basis for Processing

The first real use case of Prisma DIDs is the Action Learning Journey (ALJ), in which organizations issue contribution credentials to participants. Under the GDPR, the most direct legal bases are consent (Art. 6(1)(a)) and, for issuing organizations, performance of a contract (Art. 6(1)(b)) for data strictly necessary to deliver the credentialing service; legitimate interests (Art. 6(1)(f)) may be assessed via a balancing test but is weaker for a permanent public record. Where the reason field or credential content could reveal special-category data, an Art. 9 condition (typically explicit consent, Art. 9(2)(a)) is additionally required, which reinforces DP-02.

A structural complication applies: because on-chain data is immutable, the controller cannot fully honour withdrawal of consent (GDPR Art. 7(3)) for the subset already written to the chain. Best practice, consistent with the CNIL's position, is to (a) minimise so that only a commitment reaches the chain (R1), making the off-chain deletion effectively equivalent to erasure, and (b) inform the data subject prominently, before the first on-chain event, of the permanent and irrevocable nature of the record and its implications for the rights in Arts. 12–22. The LGPD analysis mirrors this with consent (Art. 7, I) plus, for issuers, contract performance (Art. 7, V).

5. Technical Appendix

5.1 Files Reviewed

File	Package	Role
core/vc-anchor.ts	sdk	VC event building, signing, submission
core/signature.ts	sdk	DID event signing
core/vc-verify.ts	sdk	COSE-SD credential verification
core/cose-verify.ts	sdk	COSE_Sign1 signature verification
core/payload.ts	sdk	DID event payload building
utils/keys.ts	sdk	COSE_Key extraction, multibase conversion

File	Package	Role
utils/crypto-setup.ts	sdk	Ed25519 library re-export
src/vc-event.ts	schemas	VC event Zod schema definition
worker/vc-processor.ts	indexer	VC event verification and row mapping
worker/did-terfaces	indexer	DID event verification and row mapping
worker/chain-validator.ts	indexer	DID chain integrity validation
worker/poller.ts	indexer	Blockchain polling worker
worker/processor.ts	indexer	Generic event processing pipeline
api/routes/vc.ts	indexer	VC API routes and status reducer
sources/blockfrost.ts	indexer	Blockfrost data source adapter
db/schema.ts	indexer	Database table definitions
pnpm-lock.yaml, package.json (×6)	monorepo	Dependency audit (Domain III)
.gitignore, .env.example, railway.toml	monorepo	Secret/config hygiene (Domain III)

5.2 Blockchain Data Examined

Label	Tx Hash (truncated)	Content
199674	2c641e25...a70730	DID create (duplicate #1) —  Verified on chain
199674	cf11b0ee...a6074d	DID create (duplicate #2) —  Verified on chain
199674	db02acaf...a566	DID create (different DID) —  Verified on chain
199675	114d72...cc16	VC revoke (earliest — canonical) —  Same vcHash confirmed
199675	19d65de...fdee	VC revoke (middle of 3 dupes) —  Same vcHash confirmed
199675	13c6d04...f25cc	VC revoke (latest of 3 dupes) —  Same vcHash confirmed
199675	77d0210...404f4	VC revoke (different VC) —  Verified on chain

Label	Tx Hash (truncated)	Content
199675	e856e6bd...99e0	VC issue (PII in signature blob) —  31 chunks confirmed

5.3 Consolidated Remediation Priority Matrix

Prio	Finding	Effort	CVSS / DP	Risk Reduction
P0	F-META-01 / DP-01: PII surface in on-chain signature blobs	2–4 hrs design	5.2 / High	Eliminates top remaining risk; aligns VC path with CNIL pattern
P1	F-META-03 / DP-02: Constrain reason field (enum + max length)	30 min	3.7 / High	Arms PII landmine safety
P2	F-IDX-03: Early reject for unauthorized revocations + rate limiting	1 hr	3.7	Reduces storage bloat + DoS
P3	F-SIG-01: Canonicalize signing JSON with stableSort()	1 hr	2.1	Eliminates cross-impl fragility
P4	F-KEY-03: Replace COSE_Key byte-scan with cbor.decode()	1 hr	2.7	Eliminates silent failure mode
P5	F-SIG-03: Fix DID ts signing scope	15 min	1.3	Consistent integrity model
P6	F-DEP-01: Dependency update + lockfile regeneration (pnpm update)	1 hr	Aggregate	Clears High network/framework advisories
P7	F-CFG-01: Move Pinata secret to a server route	1–2 hrs	Medium	Removes client-side secret exposure
P8	DP-04: Pinata Art. 28 DPA + SCCs	1–2 wks legal	DP Medium	Lawful international transfer
P9	DP-05: Data-subject-rights procedure + DPIA (Art. 35)	1 day + DPIA	DP Medium	Operationalises holder rights

Prio	Finding	Effort	CVSS / DP	Risk Reduction
P10	F-KEY-05: Address validation before wallet.signData()	15 min	N/A	Defense-in-depth

5.4 Limitations

Limitation	Detail
No Plutus contracts	Protocol uses metadata transactions, not on-chain scripts. Scope framed accordingly.
No dynamic testing	No fuzzing, penetration testing, or formal verification performed. On-chain data was empirically analyzed but not actively probed.
Dependency CVEs	Audited in Domain III against the supplied lockfile (Section 3.3). Live re-audit recommended after pnpm update.
Live infrastructure	Railway runtime configuration and the OWASP Top 10 web review remain open (Section 3.5), pending read-only panel access.
Data-protection scope	GDPR-led analysis with parallel LGPD mapping (Domain IV). A formal Art. 35 DPIA and a full ANPD-specific compliance opinion are recommended next steps, not performed here. No legal opinion is rendered; findings flag risk for counsel.

6. Conclusion

Prisma DIDs' on-chain interaction layer, spanning SDK, schemas, and indexer, demonstrates mature, production-quality security engineering for a TypeScript-based DID protocol operating on Cardano without Plutus contracts.

The protocol's trust core is solid: every on-chain event cryptographically verified; authorization enforced per event type; DID chain integrity guaranteed via fork detection and version monotonicity; VC status resolution deterministic and manipulation-resistant; private keys confined to the user wallet; infrastructure handles reorgs, crashes, and idempotent reprocessing gracefully. The dependency and configuration review confirms a clean cryptographic core, no Critical vulnerability on the production surface, and High-severity advisories that are predominantly availability-related and remediable by version bump, with the one actionable hardening item being the client-side exposure of the Pinata secret.

The remaining work is concentrated on data governance and privacy. Read under the GDPR, the central question is what semantically rich personal data should be permanently recorded on-chain (DP-01/F-META-01), constraining free-text input fields that can become PII vectors (DP-02/F-META-03), and putting in place the contractual and procedural instruments that lawful processing requires, an Art. 28 DPA with SCCs for the IPFS path (DP-04), and a documented data-subject-rights procedure plus an Art. 35 DPIA (DP-05). The single most valuable change is architectural, and the protocol already proves it on the DID path: anchor only a cryptographic commitment on-chain and keep the content off-chain. Bringing the Verifiable Credential path to that same pattern resolves the top technical finding and the top regulatory finding at once, and places the project squarely within the pattern recommended by the CNIL for blockchain under the GDPR.

These are refinements that strengthen privacy posture and operational resilience — not vulnerabilities that undermine the integrity or authenticity guarantees, which are strong.

Report prepared: June 25, 2026 — REFAZ Consultoria · Audit tools: Claude (Anthropic) + GLM (Zhipu AI) — dual-model cross-validation

Scoring standard: CVSS v3.1 for security findings; complementary data-protection severities for compliance findings

Primary regulatory lens: GDPR (Regulation (EU) 2016/679); secondary mapping: LGPD (Lei n° 13.709/2018)

Classification: Confidential — Recipient discretion advised before external distribution